

HUMAN RESOURCES SECURITY POLICY

Version 1.0

Revision Date: July 23, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Human Resources Security Policy
Document ID	POL-HRS-001
Current Version	1.0
Approved Date	July 23, 2026
Approved By	Information Security Steering Committee
Effective Date	July 23, 2026
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon significant change to systems, threats, or obligations
Supersedes	N/A
Audience	All personnel, including employees, contractors, consultants and interns
Next Review Date	July 23, 2027
Classification	Internal

APPROVALS

Name	Information Security Role	Signature	Date
Madhuri Chandoor	CEO and Founder		July 23, 2026
Praveen Sharma	Security Officer		July 23, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC1.1, CC1.3, CC1.4, CC1.5, CC2.2, CC6.2 and CC6.3, HIPAA Security Rule 45 CFR §164.308(a)(3), §164.308(a)(4) and §164.308(a)(5), and GDPR Articles 5, 6 and 32. Requirements apply to the extent lawful in the jurisdiction in which each person works, as set out in Section 2.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorised clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 PRIOR TO EMPLOYMENT OR ENGAGEMENT.....6

6 DURING EMPLOYMENT OR ENGAGEMENT7

7 TERMINATION AND CHANGE OF ENGAGEMENT8

8 CONTRACTORS AND THIRD-PARTY PERSONNEL8

9 ACCESS PROVISIONING AT ONBOARDING.....9

10 DEPARTURE AND ACCESS REVOCATION.....9

11 PERSONNEL SECURITY FOR AI-ASSISTED WORK 10

12 ENFORCEMENT..... 10

13 EXCEPTIONS..... 10

14 REFERENCE..... 10

15 DOCUMENT POLICY HISTORY..... 11

1 Overview and Purpose

PromptHalo Technologies (“the Company”) manages personnel security across the employment lifecycle so that individuals with access to Company and customer data are trustworthy, competent, and aware of their responsibilities. This Human Resources Security Policy defines requirements before, during, and at the end of employment or engagement.

2 Scope

This policy applies to all candidates, employees, officers, contractors, consultants, interns, and temporary workers of the Company.

Every requirement in this policy applies only so far as it is lawful and customary in the place where the person works. Personnel are engaged in several jurisdictions, and screening, record retention and disciplinary practice differ between them. Where a requirement cannot lawfully be met locally, the Company records that fact against the person's engagement and applies the nearest lawful equivalent; it does not treat the position as a deficiency. [SOC 2: CC1.1, CC1.4, CC5.3]

Where this policy calls for a check, a record or a tool, the Company uses the most cost-optimal option that satisfies the requirement. A free or already-owned mechanism is preferred to a paid one, a shared record to a new system, and an existing cadence to a new one. Nothing in this policy requires the purchase of a human resources platform, a screening subscription or a learning management system. [SOC 2: CC1.4, CC5.3]

3 Roles and Definitions

1. “The Company” refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
3. **Contractor** — an individual engaged under a contract for services rather than employment, who holds Company or client access.
4. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.

6. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
7. **Joiner, mover, leaver** — the three events that change a person's access: starting, changing role, and departing.
8. **Offboarding record** — the dated evidence that a departure was processed, including access revocation timestamps and asset return.
9. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
10. **Sanctions process** — the documented and consistently applied process for addressing policy violations.
11. **Screening** — identity verification and background checks proportionate to the role and permitted by applicable law.
12. **Security Officer** — the individual accountable for day-to-day operation of the security program.
13. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
14. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.
15. **Trusted role** — a role holding administrative access to production, customer data, or the identity provider.

5 Prior to Employment or Engagement

1. Before anyone is given access to Confidential or Restricted information, the Company confirms who they are and carries out checks proportionate to the access involved and permitted by local law. Identity and right to work is the baseline for everyone; anything beyond that is set by the tier in the Screening Standard. Where a contractor is engaged through a firm, that firm's written confirmation that it has screened them is accepted in place of the Company repeating the check. [SOC 2: CC1.1, CC1.4 • HIPAA §164.308(a)(3)]
2. The screening record notes the tier applied, the date and who reviewed it. It is completed before access is granted, and access is not set up until it exists. [SOC 2: CC1.1, CC1.4]
3. Engagements are conditioned on a signed agreement covering confidentiality, intellectual property and acceptance of the Company's security policies, including the Code of Conduct. [SOC 2: CC1.5, CC2.2]
4. Each role has a short description — a paragraph is enough — setting out what the role is responsible for securing and any skill or certification the Company relies on. Four to six of these

cover the Company at its current size, and a certification a person relies on is confirmed once at engagement rather than re-verified. [SOC 2: CC1.4, CC1.3]

5. Screening is carried out to the extent permitted and customary in the person's jurisdiction. Where a criminal record check is unlawful, restricted or disproportionate locally, identity and right-to-work confirmation is sufficient and the reason is noted on the screening record. The least expensive lawful route is used: a self-declaration with documentary evidence, or the engaging firm's written confirmation, in preference to a paid screening service. [SOC 2: CC1.1, CC1.4 • HIPAA §164.308(a)(3)]

6 During Employment or Engagement

1. Everyone completes security awareness training when they join and once a year after that, and accepts the Company's policies on the same cadence. The acceptance record shows the individual, the version accepted and the date, and acceptances are reset when a policy materially changes so that what is held is acceptance of the current version. [SOC 2: CC1.1, CC1.4, CC2.2]
2. Access is granted, changed and reviewed under the Access Control Policy as roles change. [SOC 2: CC6.2, CC6.3]
3. Anyone who becomes aware of a role change, an extended absence or a conduct concern bearing on system access tells the Security Officer. The Company has no management layer, so this sits with whoever knows rather than necessarily with a manager unless the manager resides. [SOC 2: CC1.5, CC6.2]
4. Once a year the CEO or CEO's delegate records, in a single dated note covering everyone, that each person's security and control responsibilities have been discussed and are being met. The Company runs no formal performance cycle and this note is what satisfies the requirement; it is made in the same sitting as the annual control environment assessment. [SOC 2: CC1.5]
5. Where a policy is breached, the Security Officer sets out the finding and recommends what should happen, and the CEO decides, records the decision and applies it consistently. Each case gets a short dated note of the finding, the decision and the reason for it, written even where the decision is to do nothing further, and any departure from how a comparable case was handled is explained in that note. [SOC 2: CC1.1, CC1.5]
6. Personnel acknowledge the Code of Conduct's remote working expectations — the device measures, and handling screens, conversations and printed material away from a Company location — inside the same annual acceptance. There is no separate remote working form. [SOC 2: CC1.4, CC6.4]
7. Training may be delivered through free or already-licensed material — the provider's own security modules, a short internally written briefing, or open courseware — provided completion is recorded. A paid awareness platform is not required at the Company's current size. [SOC 2: CC1.4, CC2.2]

7 Termination and Change of Engagement

1. Access is revoked when someone leaves or their role changes, on the timing and by the steps set out in Section 10. That section is the operative one; this section states the obligation, not a second process. [SOC 2: CC6.2, CC6.3]
2. Company equipment and credentials are returned, and the person confirms they have deleted Company information from their own devices and accounts. Confidentiality obligations continue after the engagement ends and are restated in the departure note. [SOC 2: CC6.5, CC1.1 · HIPAA §164.310(d)(1)]

8 Contractors and Third-Party Personnel

The Company engages contractors and consultants alongside employees. Their access is often equivalent, so their controls shall be equivalent. Where an obligation cannot be imposed by employment, it shall be imposed by contract.

1. Contractors, consultants and fractional personnel are held to the same screening, security awareness training and policy acknowledgment requirements as employees, proportionate to the access they hold and to the extent lawful where they work. Almost everyone engaged by the Company works on this basis, so this is the ordinary case rather than an exception. [SOC 2: CC1.4, CC1.1 · HIPAA §164.308(a)(3)]
2. Where an engaging firm carries out the screening, or where local employment or data protection law limits what the Company may ask of someone directly, the firm's written confirmation that equivalent checks were completed is kept in place of the underlying record. The Company does not ask anyone to submit to a check that would be unlawful where they work. [SOC 2: CC1.4, CC9.2]
3. The simplest way to hold contractors to the same set is to assign them the same policy, training and screening items as employees in whatever the Company already uses to keep track of people. Where it keeps no such system, one shared list serves the same purpose. No particular platform is required. [SOC 2: CC1.4, CC5.3]
4. Engagement terms incorporate the Code of Conduct and the Acceptable Use Policy by name, together with the confidentiality and intellectual property terms required of employees. [SOC 2: CC1.1, CC9.2]
5. Every contractor has a named internal sponsor accountable for their access, their onboarding and starting their offboarding. At this size that is usually the person who engaged them. [SOC 2: CC1.3, CC6.2]
6. Each engagement carries an end date — recorded in the identity provider where it supports one, and otherwise on the personnel list — so that access lapses rather than persisting unnoticed. Access is reviewed at renewal and at the access review under the Access Control Policy, and access is suspended where someone has not worked on an engagement for ninety days. [SOC 2: CC6.2, CC6.3]
7. Where a contractor works from equipment the Company does not manage, work is done in the Company's cloud services under the conditions in the Code of Conduct, and Confidential or Restricted information is not stored locally. [SOC 2: CC6.4, C1.1 · GDPR Art. 32]

9 Access Provisioning at Onboarding

The Company uses a single identity provider, and joiners are provisioned through it. Provisioning is where least privilege is either established or lost.

1. Access shall be requested and approved before it is granted, and the request record shall name the approver and the date. [SOC 2: CC6.2 • HIPAA §164.308(a)(4)]
2. New personnel shall be granted a defined baseline role appropriate to their position rather than access copied from an existing user, since copied access propagates entitlements nobody has reviewed. [SOC 2: CC6.3]
3. Access to production systems, customer data and Google Workspace administration is approved separately by the CEO or her delegate. [SOC 2: CC6.3]
4. Applications shall be reached through single sign-on wherever technically possible, so that a single suspension at departure removes access everywhere. [SOC 2: CC6.1, CC6.2]
5. Onboarding shall not be marked complete until policy acknowledgement and initial security training are recorded. [SOC 2: CC1.4, CC2.2]
6. The onboarding checklist shall be completed and retained for every joiner, employee or contractor alike, covering policy acceptance, training assignment, screening record, access granted in AWS, GitHub and the Google Workspace identity provider, other relevant resources, and any equipment issued. The completed checklist is the evidence that onboarding occurred; a joiner without one is a finding. [SOC 2: CC1.4, CC6.2]

10 Departure and Access Revocation

The personnel list is the authoritative trigger for revocation. Everything downstream depends on that entry being made promptly and accurately.

1. The Company runs no human resources system. A departure is recorded on the personnel list by the Security Officer or the person's sponsor, and that entry is what triggers offboarding. A departure agreed in conversation is not complete until it is written there. [SOC 2: CC6.2 • HIPAA §164.308(a)(3)(ii)(C)]
2. Google Workspace access, AWS access, and other resources as relevant is suspended on the last working day, and immediately where the departure is involuntary. The suspension timestamp is the evidence and no separate record is needed. [SOC 2: CC6.2]
3. Access that does not run through Google Workspace sign-in is listed by name on the offboarding checklist and removed one by one — AWS, GitHub, any shared credential in the password manager, and any third-party model or AI service. The list is short at this size and is kept current as tools change. [SOC 2: CC6.2, CC6.3]
4. The offboarding checklist is completed and kept for every departure, and records the date access was removed. Where the person owned an agent or an automated workflow, that ownership is passed to someone else before their access goes. [SOC 2: CC6.2, CC1.3]

11 Personnel Security for AI-Assisted Work

Personnel use assistive and agentic AI tools in the course of their work. The obligations below sit with the individual and are established at onboarding.

1. AI tools are used through Company accounts rather than personal ones, and Company or client information is not entered into free or consumer tiers of any AI service. Which tools are approved is maintained under the AI Governance Policy; this policy does not keep a second list. [SOC 2: CC1.1, CC6.1]
2. Training at onboarding and annually covers which classifications may be entered into which tools, and the rule that a named person remains accountable for any output relied upon. [SOC 2: CC1.4]
3. Where someone owns an agent or an automated workflow, that ownership is recorded against their role and passed to someone else during offboarding, before their access is removed. [SOC 2: CC1.3, CC6.2]
4. AI-generated work is not presented as verified unless the person has verified it, and concerns about output quality are raised rather than passed on. [SOC 2: CC1.1]

12 Enforcement

1. Violations of this policy may result in disciplinary action up to and including termination of employment or engagement, and, where applicable, civil or criminal referral.
2. Disciplinary decisions shall be documented by the Security Officer and applied consistently, in accordance with the Company's personnel sanctions process.

13 Exceptions

Exceptions to this policy must be requested in writing to the Security Officer and approved by the Information Security Steering Committee before taking effect. Approved exceptions shall be documented, risk-assessed, time-bound, and reviewed at least annually.

14 Reference

1. SOC 2 Trust Services Criteria (CC1.4, CC1.5)
2. Human Resources Security Policy
3. Security Awareness and Training Policy
4. Access Control Policy
5. Code of Conduct (POL-COC-001)
6. Access Control Policy
7. Acceptable Use Policy
8. Security Awareness and Training Policy
9. Vendor Management Policy

10. HIPAA Security Rule, 45 CFR §164.308(a)(3) and §164.308(a)(5)

11. EU General Data Protection Regulation, Articles 5, 6 and 32

15 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	July 23, 2026	Initial policy release